A02 - Security Misconfiguration

- **Problem:** Insecure configuration of applications, servers, or cloud services that introduces vulnerabilities
- **Impact:** Unauthorized access, data exposure, or system compromise

Common vulnerabilities:

- **Default credentials:** Unchanged passwords or accounts
- **Unnecessary features:** Exposed ports, services, or debugging tools
- **Insecure permissions:** Misconfigured cloud storage or access controls
- **Information leakage:** Verbose error messages or stack traces
- **Missing security settings:** Disabled protections or missing HTTP security headers
- **Outdated configurations:** Legacy or insecure settings retained after upgrades

Preventing Security Misconfiguration

- **Secure by default:** Apply hardening guidelines across the entire stack
- **Minimize attack surface:** Disable unnecessary features, services, and accounts
- **Automate configuration:** Use consistent, repeatable configurations across environments
- **Keep configurations updated:** Review security settings after patches and upgrades
- **Enforce isolation:** Segment components and restrict cloud permissions
- **Secure credentials:** Avoid hardcoded secrets; use short-lived credentials
- **Validate security:** Automate configuration checks, restrict error details, and enforce security headers